

Incident Review: SOC Ticket vs. GRC Write-Up

GRC Practicum — Project 1 | NOVAtch Inc. (simulated scenario)

Note: NOVAtch Inc. is a fictional company; this incident is simulated for the purpose of demonstrating the difference between operational (SOC) and governance (GRC) documentation of the same event. The structure reflects real-world SOC and GRC writing conventions.

The Incident

A user reported a suspicious email. Investigation revealed one employee entered credentials on a fake Microsoft 365 login page; the account was accessed from a foreign IP before containment.

VERSION A — The SOC Ticket

(How security operations documents an incident: chronological, technical, action-focused)

INC-4521 | Severity: High | Status: Resolved

Alert: Impossible-travel sign-in detected for j.doe@novatech.io (Edmonton 09:02 → foreign IP 09:47).

Investigation: Reviewed M365 sign-in logs; confirmed successful authentication from unfamiliar IP/device following user-reported phishing email. Detonated URL in sandbox, confirmed credential-harvesting page mimicking the M365 login portal. Extracted IOCs (sender domain, URL, harvester infrastructure IP).

Scope check: Searched mail flow : phishing email delivered to 14 recipients; 1 confirmed click/credential entry. Inspected compromised mailbox, one malicious auto-forward rule identified and removed. Reviewed audit logs for data access; no bulk download or exfiltration observed.

Containment (in order): Disabled account → revoked all active sessions and refresh tokens → forced password reset → blocked sender domain and URL at email gateway and proxy → removed the forwarding rule → notified remaining 13 recipients and purged the email from mailboxes.

Recovery: Account re-enabled following password reset and MFA re-registration. IOCs added to blocklists and threat intelligence platform.

Closure: No evidence of lateral movement or data exfiltration. Ticket closed.

VERSION B — The GRC Write-Up

(How governance documents the same incident: control-focused, root-cause driven, forward-looking)

Incident Review — Credential Compromise via Phishing (Ref: INC-4521)

Control failure analysis: The incident succeeded because of three control gaps:

1. **MFA was not enforced for this user group** — a coverage gap in the authentication standard (ISO 27001 A.8.5 / A.5.17). The phishing page harvested a password that, alone, was sufficient for access.
2. **Email filtering did not detect the phishing URL** — a detective control gap (A.8.7, informed by A.5.7 threat intelligence).
3. **The user had not completed the current awareness training cycle** (A.6.3) — organizational completion stood at 71% against a 95% target, and no escalation process existed for non-completion.

Root cause: The MFA rollout was exception-based: ~12% of accounts were excluded for compatibility reasons, with **no compensating control and no documented risk acceptance**. The exposure existed for months because no one owned the exception list.

Risk exposure: Unauthorized access to corporate email and connected SaaS applications. The compromised mailbox contained customer correspondence; had exfiltration occurred, a PIPEDA Real-Risk-of-Significant-Harm assessment and possible OPC reporting would have been triggered. The auto-forward rule indicates attacker intent to persist and collect.

Corrective actions:

#	Action	Owner	Due	Closes
1	Enforce MFA tenant-wide; any exception requires CISO-approved risk acceptance with expiry date	IT Manager	30 days	Root cause
2	Awareness-training completion added to quarterly compliance dashboard with manager escalation below 90%	GRC	45 days	Gap 3
3	Add impossible-travel and new-inbox-rule detections as standing SIEM use cases	Security Ops	21 days	Detection depth (A.8.16)

Recurrence monitoring: MFA coverage % and training completion % reported monthly; phishing-simulation click rate tracked quarterly. **Residual risk after actions: Low.** Review scheduled at next management review.

THE STRUCTURE — What Makes Each Version Work

Version A anatomy (SOC ticket)

Element	Job it does
Header (ID, severity, status)	Makes the record findable and triage-able
Alert	What fired and when (the entry point)

Investigation	What you checked, what confirmed the compromise (evidence chain)
Scope check	How far it spread (the blast radius question)
Containment, in order	What you did; sequence matters (disable before reset, revoke sessions before re-enable)
Recovery + closure	Return to normal + the "no further evidence" statement

Version A's implicit question: *"What happened and is it over?"*

Version B anatomy (GRC write-up)

Element	Job it does
Control failure analysis	Names WHICH controls failed, mapped to a framework — turns an event into a control statement
Root cause	Keeps asking "why" past the technical cause until it hits a process/governance gap — here, an unowned exception list
Risk exposure	Translates to business language: data, regulatory angle, worst case
Corrective actions with owner + date	Fixes the process, not the incident; unowned actions are wishes
Recurrence monitoring	The metrics that prove the fix holds
Residual risk statement	The formal "where does this leave us" (connects back to risk appetite)

Version B's implicit question: *"Why was this possible, and what changes so it isn't?"*

The five translation moves (SOC → GRC)

1. **Event** → **Control**: every "attacker did X" becomes "control Y should have prevented/detected X and didn't"
2. **User error** → **Governance gap**: never stop at "user clicked"; find the unowned process behind the exposure
3. **Technical impact** → **Business risk**: logs and hosts become data categories, regulatory triggers, and dollar-shaped consequences
4. **Actions taken** → **Actions owned**: past-tense fixes become future-tense commitments with names and dates
5. **Ticket closed** → **Metrics watched**: closure isn't the end state; sustained measurement is